



RELAZIONE DI LABORATORIO DI CYBERSECURITY

Simulazione di un Attacco Ransomware e Analisi di un Trojan Bancario



Dati dello Studente

Campo	Dettaglio
Nome e Cognome	Lorenzo Rizzuti
Corso di Studi	Epicode
Anno Accademico	2025/2026
Docente	Paolo Rampino 🧡💖
Data di Consegna	21/07/2026



Indice dei Contenuti

1. Introduzione
2. Obiettivi del Progetto
3. Ambiente di Laboratorio
 - 3.1 Architettura del Sistema
4. Esecuzione del Laboratorio
 - 4.1 Parte 1: Caricamento e analisi di WannaCrypt0r.exe
 - 4.2 Parte 2: Esecuzione e monitoraggio di DanaBot.exe
5. Analisi dei Risultati
 - 5.1 WannaCrypt0r.exe – Sandboxing
 - 5.2 DanaBot.exe – Analisi Dinamica e di Rete
6. Contromisure e Difese
7. Conclusioni
8. Riferimenti e Tool Utilizzati

1. Introduzione

Il ransomware rappresenta una delle minacce informatiche più pervasive e dannose del panorama digitale contemporaneo. Secondo un recente rapporto di Sophos, il settore dell'istruzione è particolarmente vulnerabile: il 55% degli istituti scolastici ha finito per pagare più del riscatto inizialmente richiesto, con costi medi di ripristino che raggiungono i 3 milioni di dollari. Gli attacchi ransomware nel settore educativo sono aumentati del 69% su base annua, colpendo il 63% degli istituti scolastici.

Un ransomware è un tipo di malware che crittografa i file della vittima e richiede un pagamento (riscatto) in cambio della chiave di decrittazione. Il suo ciclo di vita tipico è:

- Infezione: il malware viene eseguito sul sistema target.
- Generazione Chiave: viene creata una chiave di crittografia univoca.
- Crittografia: i file vengono cifrati con algoritmi come AES-256 e RSA.
- Riscatto: viene mostrato un messaggio che richiede il pagamento in criptovalute.
- Decrittazione: solo se il riscatto viene pagato, i file vengono ripristinati.

I ransomware moderni adottano spesso una crittografia ibrida (AES-256 per i file, RSA per la chiave AES), approccio utilizzato da minacce celebri come WannaCry e CryptoLocker.

Questa relazione documenta un laboratorio didattico di analisi malware condotto in ambiente controllato. Le attività svolte comprendono l'analisi comportamentale del ransomware WannaCrypt0r e l'analisi dinamica del trojan bancario DanaBot.

2. Obiettivi del Progetto

Il laboratorio si è posto i seguenti obiettivi:

- Analisi Comportamentale Sicura: utilizzare una piattaforma di sandboxing cloud (Recorded Future Triage) per eseguire e analizzare il ransomware WannaCry senza mettere a rischio l'infrastruttura locale.
- Analisi Dinamica e di Rete: eseguire il trojan bancario DanaBot in una macchina virtuale isolata (FlareVM) e studiarne l'impatto a livello di sistema operativo (Process Monitor) e di rete (Wireshark su Kali Linux).
- Verifica OSINT: validare i risultati ottenuti tramite piattaforme di threat intelligence (VirusTotal) per confermare la natura malevola dei campioni analizzati.

3. Ambiente di Laboratorio

Per garantire la sicurezza e l'isolamento delle operazioni, il laboratorio è stato allestito su un'infrastruttura di virtualizzazione.

3.1 Architettura del Sistema

- Hypervisor: Oracle VirtualBox.
- Macchina di Analisi (FlareVM): Windows 10/11 configurato con strumenti di reverse engineering e monitoraggio (Sysinternals Suite, Process Hacker, PE-bear).
- Macchina di Rete (Kali Linux): istanza Linux utilizzata per il monitoraggio del traffico di rete tramite Wireshark.
- Sandbox Cloud: piattaforma Recorded Future Triage, impiegata per l'esecuzione sicura del campione WannaCrypt0r.exe.

4. Esecuzione del Laboratorio

4.1 Parte 1: Caricamento e analisi di WannaCrypt0r.exe

Il campione WannaCrypt0r.exe è stato caricato sulla piattaforma Recorded Future Triage. La sandbox ha eseguito il file in un ambiente Windows virtualizzato, registrando tutte le attività di processo, file system, registro e rete. Al termine dell'esecuzione è stato generato un report dettagliato con punteggio di gravità 10/10.

4.2 Parte 2: Esecuzione e monitoraggio di DanaBot.exe

Il campione DanaBot.exe è stato eseguito localmente su FlareVM. Prima dell'avvio, sono stati attivati Process Monitor (Procmon) per la cattura delle operazioni di sistema e Wireshark sull'interfaccia di rete bridged per intercettare il traffico. L'esecuzione è stata mantenuta per il tempo necessario a osservare i comportamenti malevoli, quindi il malware è stato terminato e la macchina virtuale ripristinata.

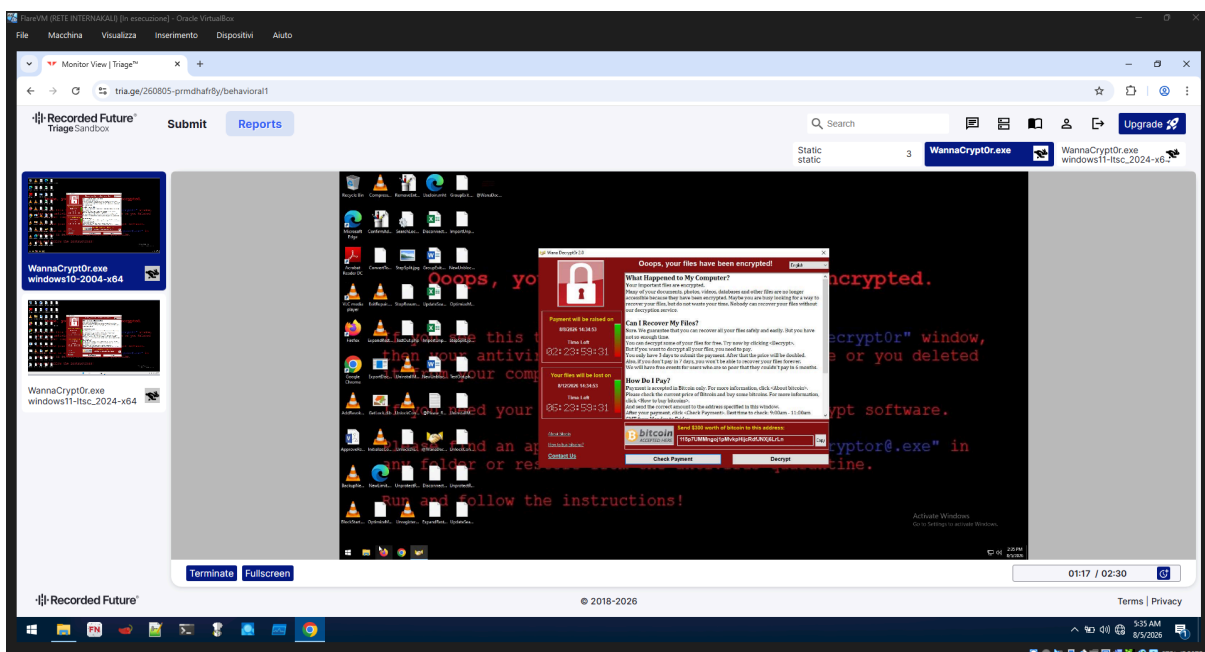
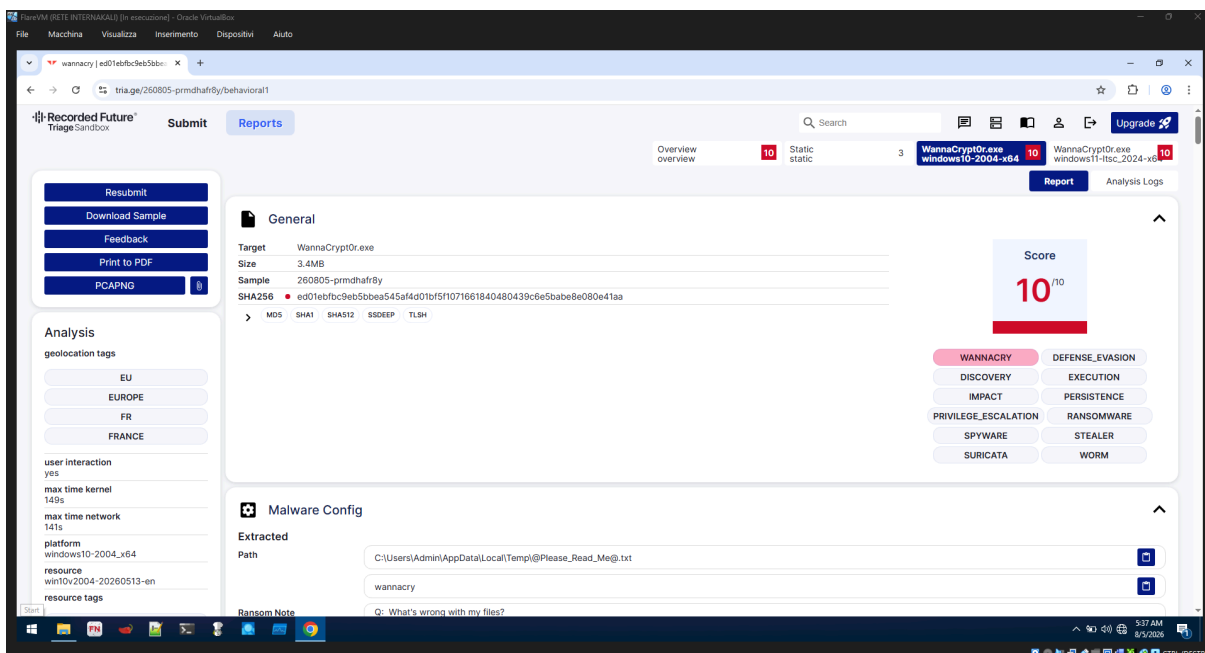
5. Analisi dei Risultati

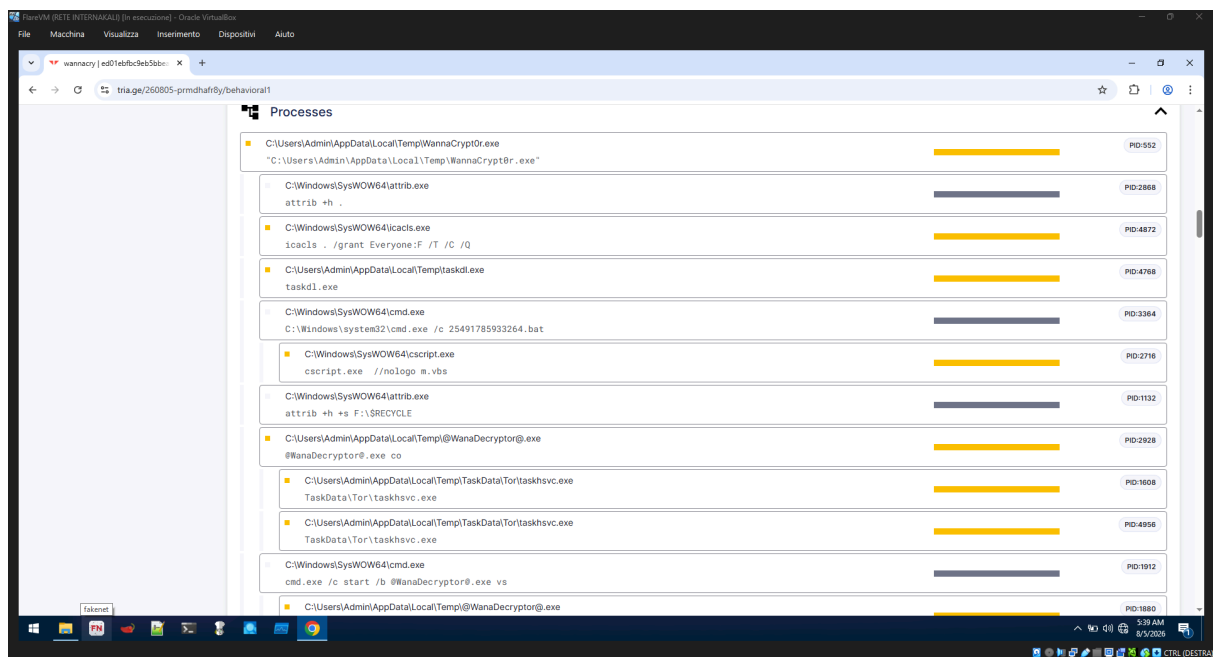
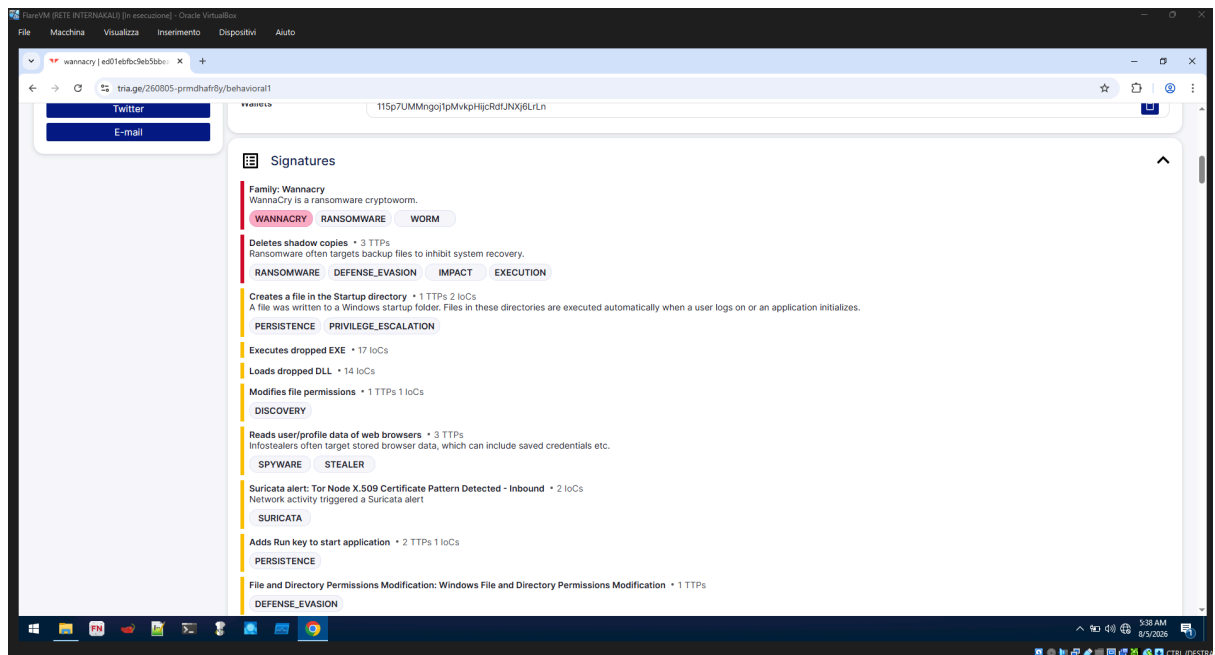
5.1 WannaCrypt0r.exe – Sandboxing

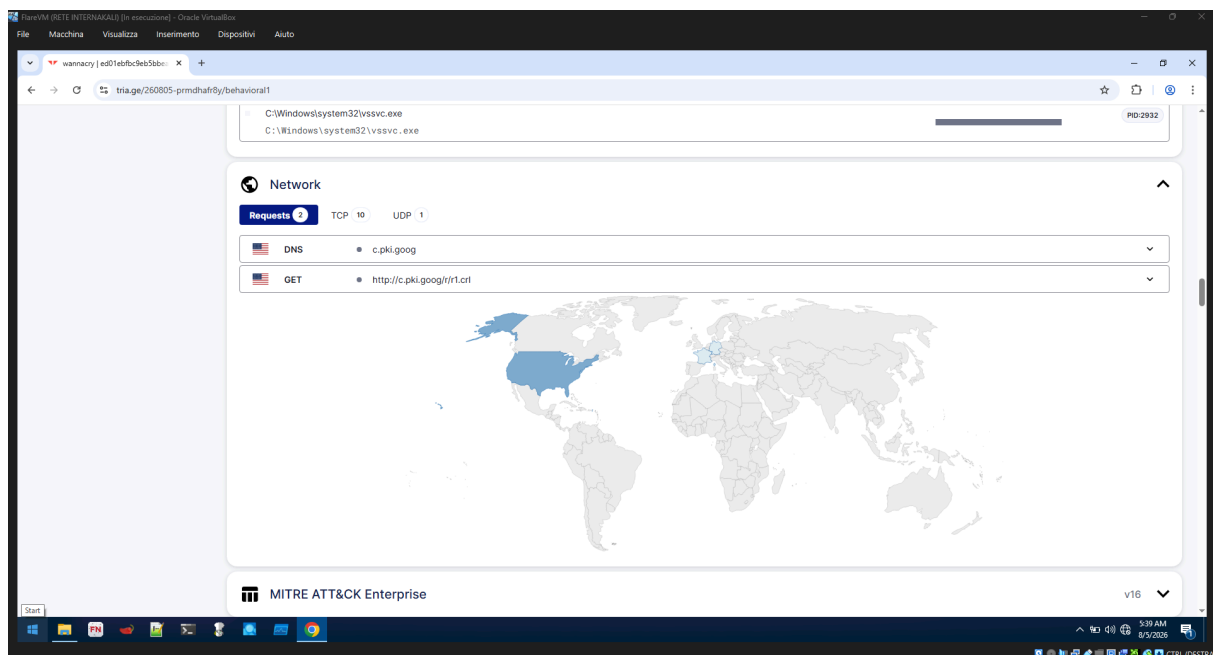
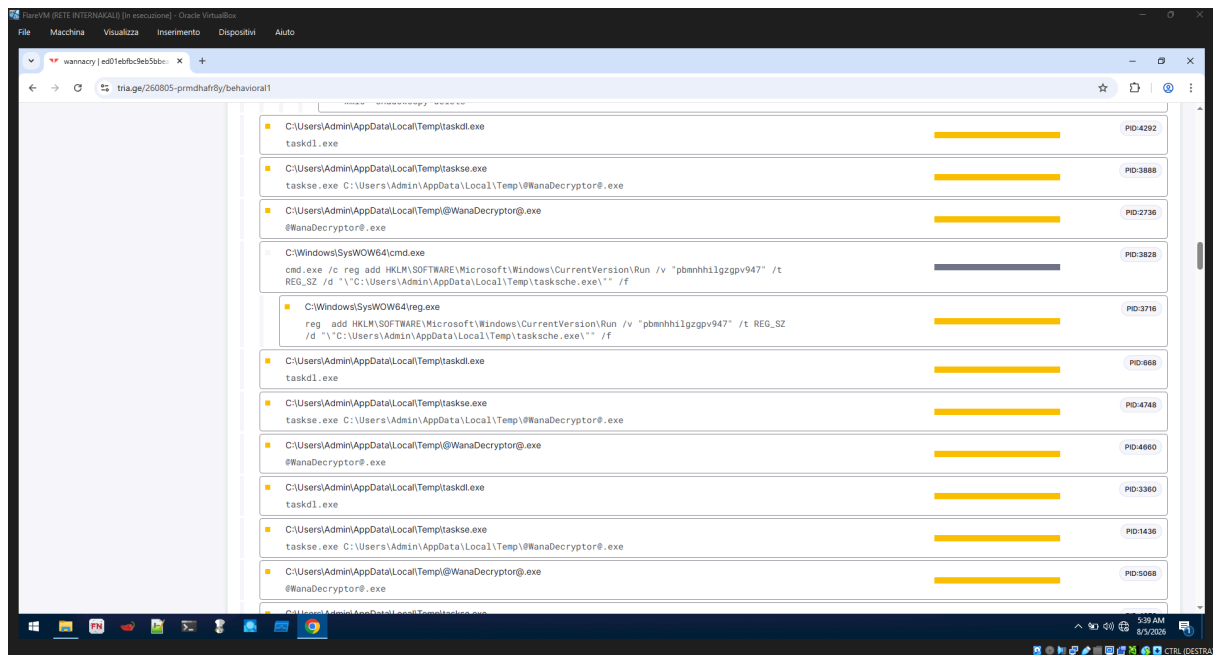
- Rilevamento: il report ha assegnato un punteggio di gravità 10/10, identificando il campione come appartenente alla famiglia WannaCry. Il

Malware Config ha estratto automaticamente il percorso del file di riscatto (C:\Users\Admin\AppData\Local\Temp@Please_Read_Me@.txt).

- **Firme Comportamentali (MITRE ATT&CK):** le evidenze hanno mostrato la cancellazione delle Shadow Copies (per impedire il ripristino dei file), l'aggiunta di chiavi Run nel registro di sistema (persistenza) e l'uso di `cmd.exe` e `cscript.exe` per l'esecuzione di payload malevoli.
- **Rete:** il malware ha effettuato richieste verso il dominio `c.pki.goog`. Questo comportamento è storicamente associato al meccanismo di "kill-switch" di WannaCry.





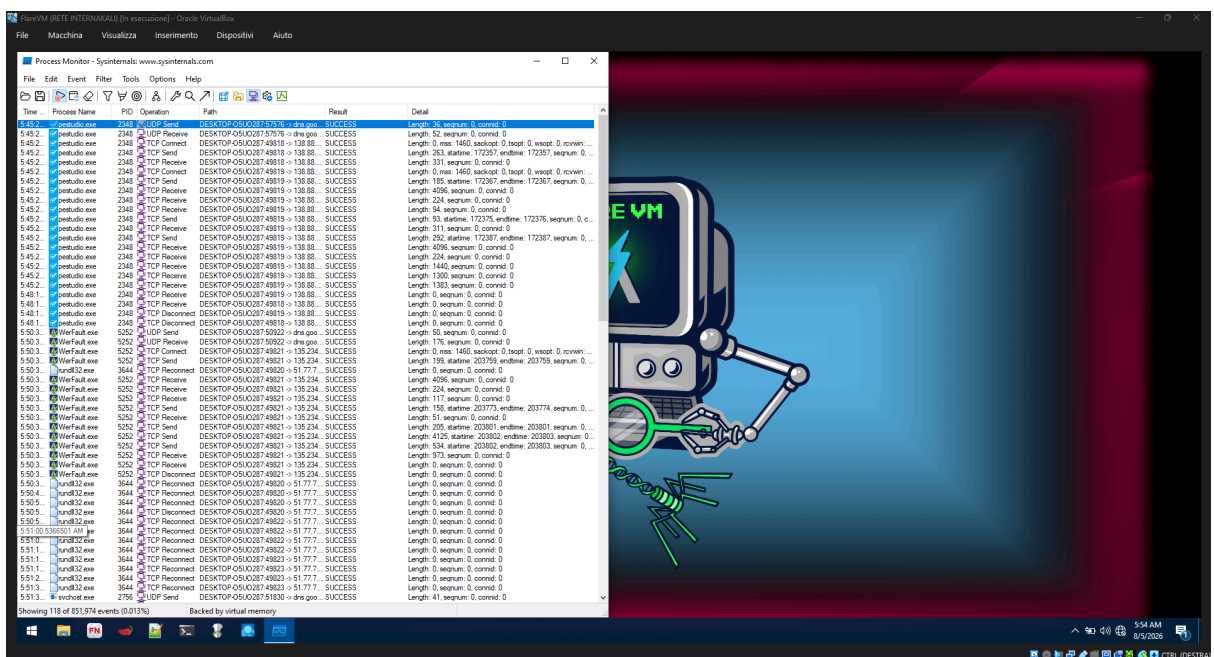
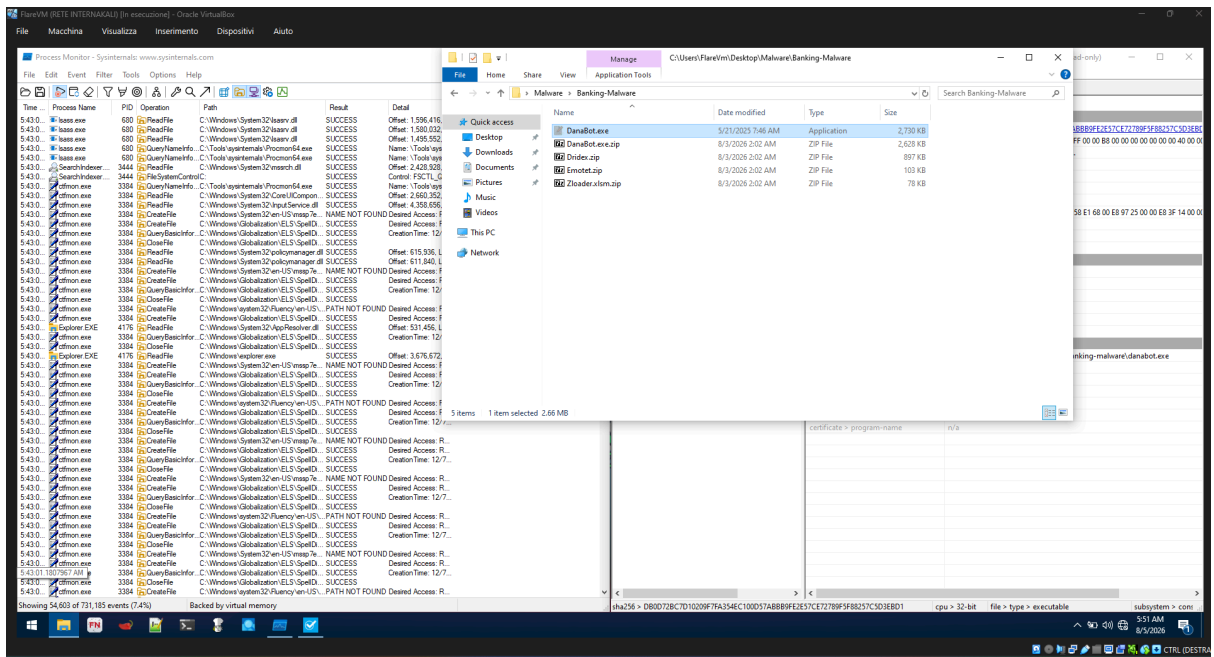


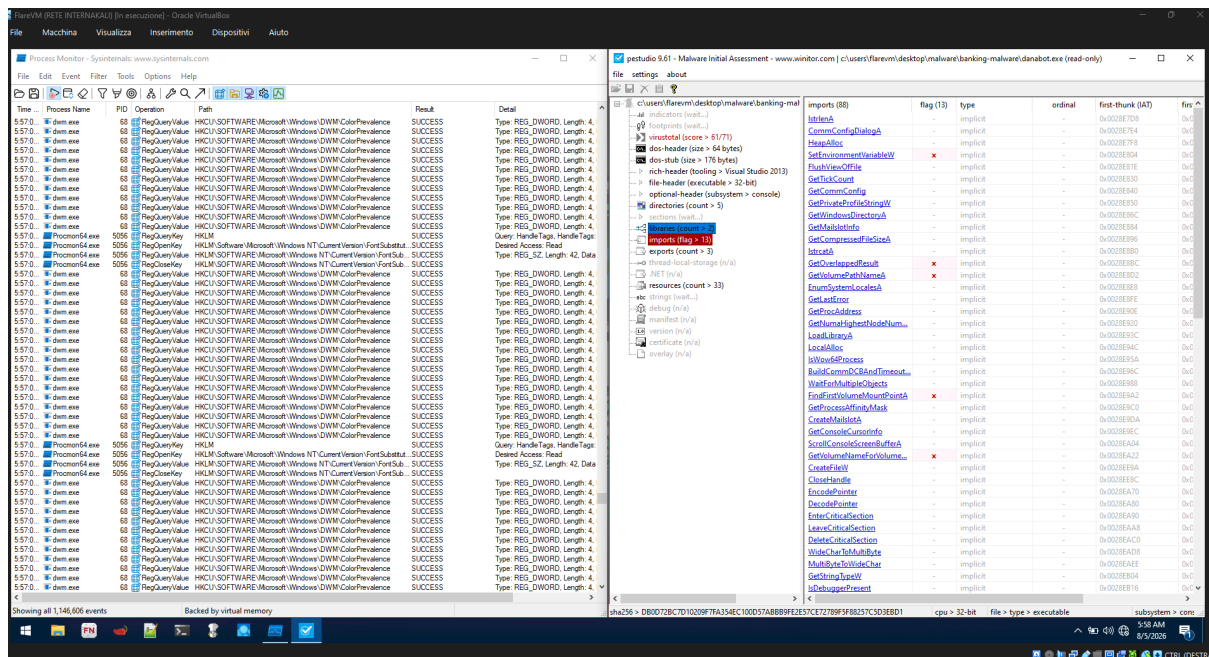
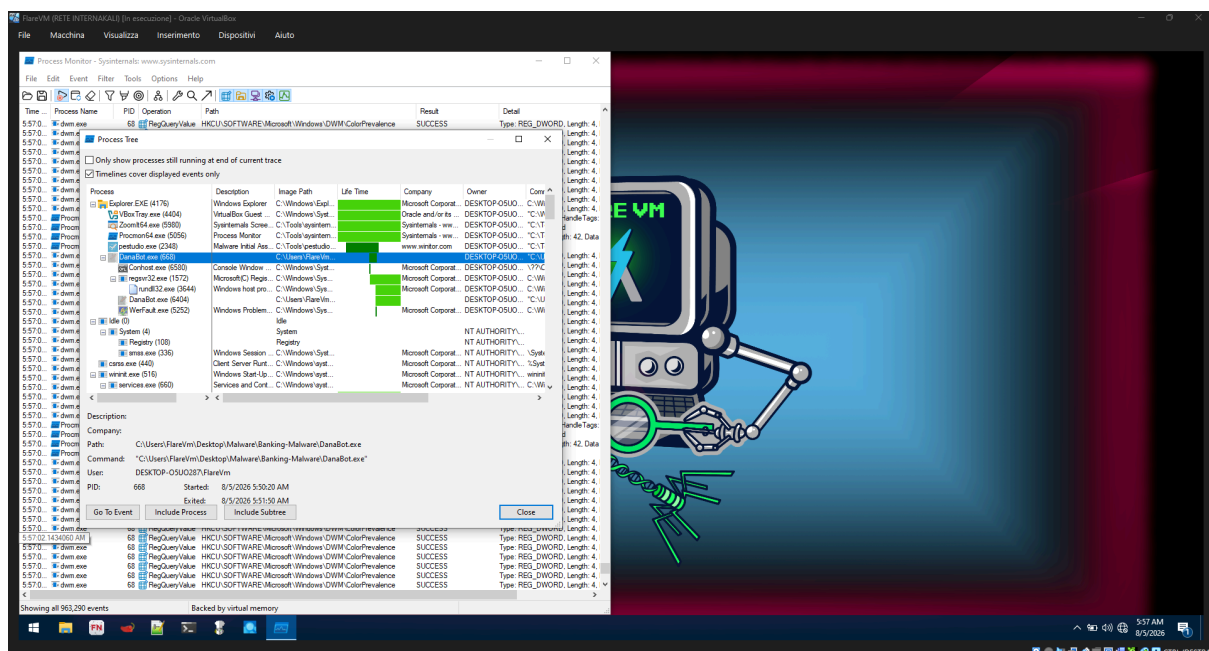
5.2 DanaBot.exe – Analisi Dinamica e di Rete

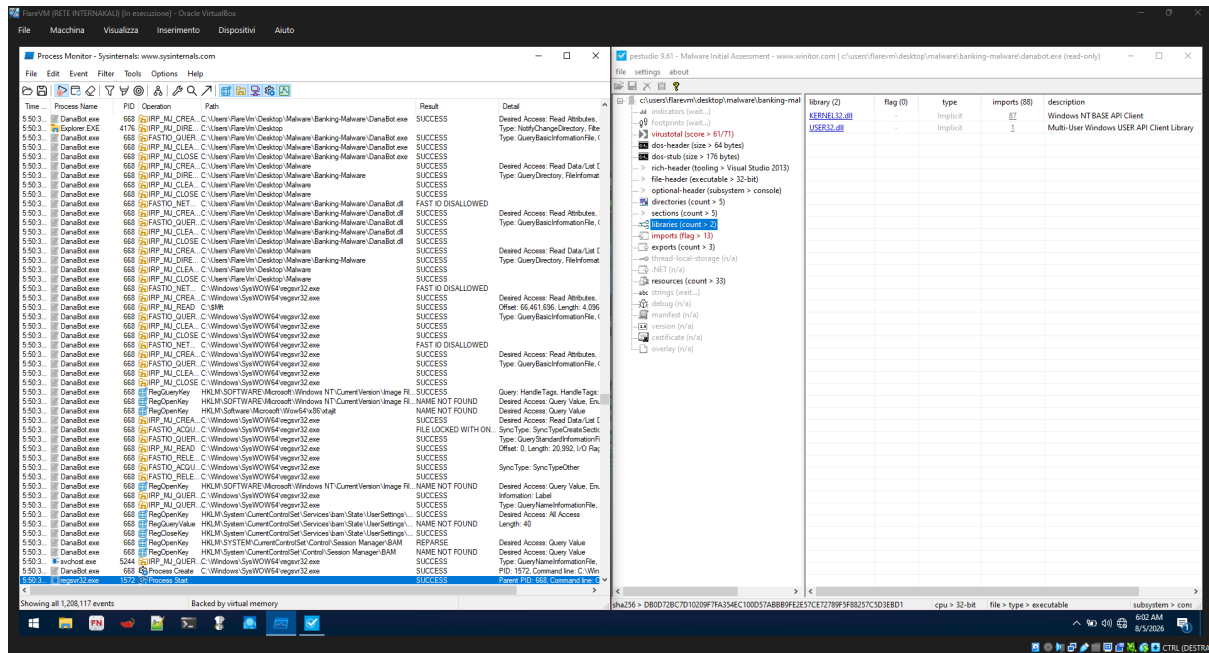
- **Analisi dei Processi (Procmon):** l'esecuzione ha generato un intenso accesso al registro di sistema (RegQueryValue, RegOpenKey), in particolare verso le

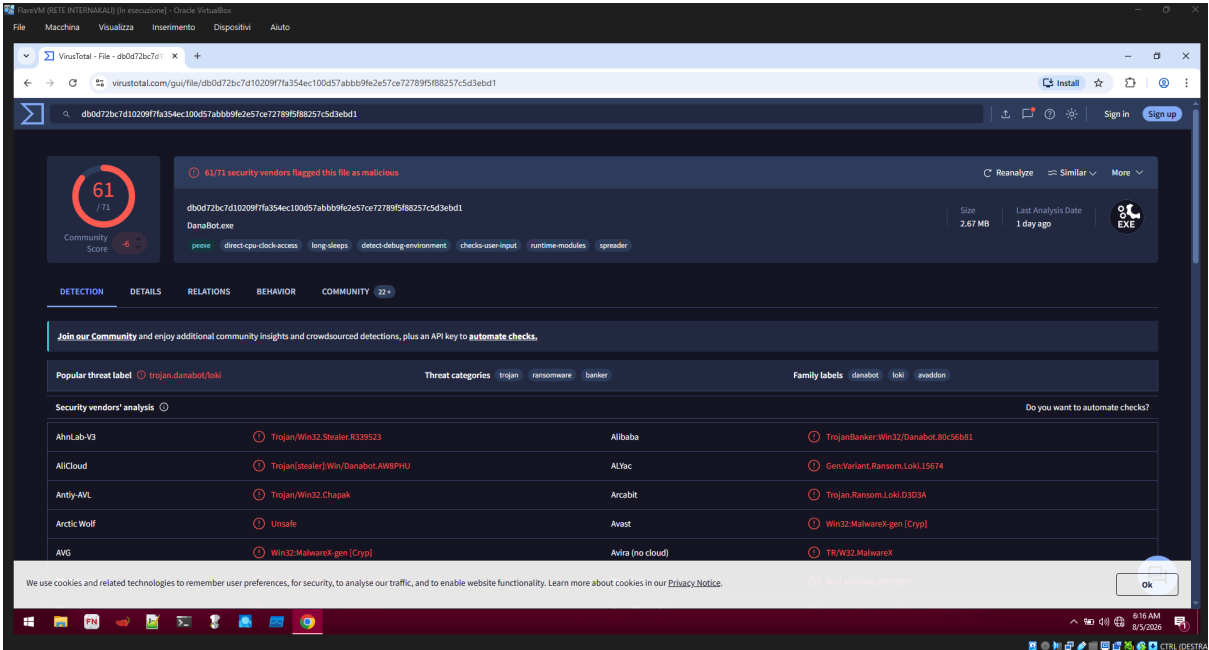
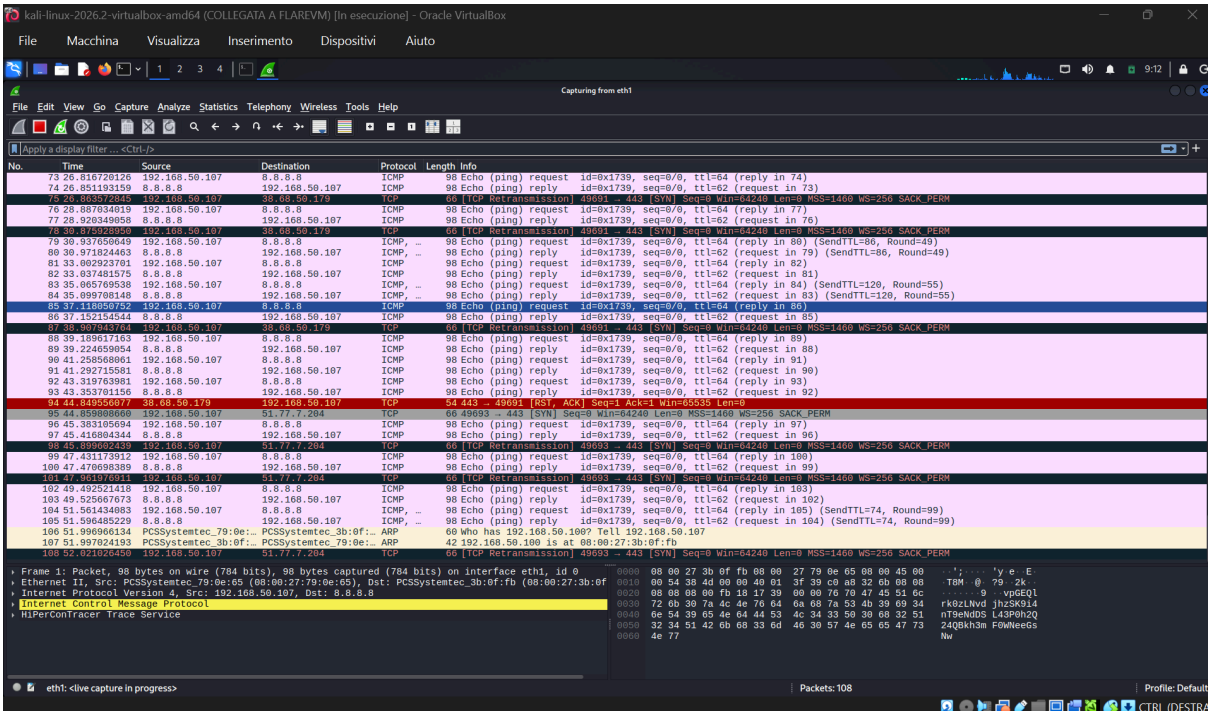
chiavi di configurazione del Firewall di Windows, segno di un tentativo di disabilitare le difese del sistema.

- Analisi Statica (PE-bear): dall'analisi delle Import Address Table (IAT) è emerso che l'eseguibile importa funzioni critiche da KERNEL32 .d11 (manipolazione file) e USER32 .d11.
- Analisi di Rete (Wireshark): il malware ha inviato pacchetti ICMP (Ping) verso 8.8.8.8 (Google DNS) per verificare la connettività. Sono state registrate connessioni TCP sulla porta 443 verso l'IP esterno 51.77.204.204. I pacchetti di ritrasmissione (TCP Retransmission) indicano un tentativo di contattare un server C2 che non ha risposto.









6. Contromisure e Difese

Le vulnerabilit  osservate possono essere mitigate attraverso i seguenti accorgimenti:

- Aggiornamenti di Sicurezza: la diffusione di WannaCry è stata possibile grazie a una vulnerabilità SMB (EternalBlue) già patchata da Microsoft. Mantenere i sistemi operativi aggiornati è la difesa primaria.
- Backup Offline: adottare backup immutabili o su supporti fisici rimossi dopo il backup.
- Segmentazione di Rete: limitare la connettività in uscita tramite firewall verso IP sconosciuti.
- Strumenti EDR: l'uso di Endpoint Detection and Response permette di rilevare in tempo reale l'esecuzione anomala di processi come `cmd.exe`.

7. Conclusioni

L'esercitazione ha permesso di validare due diverse metodologie di analisi malware. L'uso della sandbox cloud per WannaCry ha dimostrato come analizzare ransomware noti senza rischi, mentre l'analisi dinamica di DanaBot ha messo in luce il comportamento tipico di un trojan bancario: disabilitare le difese di sistema e tentare di comunicare con infrastrutture C2 per la potenziale esfiltrazione di dati. La correlazione tra le osservazioni di rete e la verifica di intelligence (VirusTotal) ha confermato la natura malevola di entrambi i campioni.

8. Riferimenti e Tool Utilizzati

- Recorded Future Triage – Piattaforma di sandboxing.
- Sysinternals Process Monitor (Procmon) – Monitoraggio dei processi.
- PE-bear – Analisi statica degli eseguibili.
- Wireshark – Analisi del traffico di rete.
- VirusTotal – Piattaforma di Threat Intelligence.
- Sophos Report 2025 – Dati statistici sui ransomware nel settore educativo.